

FiHaven — Access Control Policy

Owner	Daniel Hipskind (FiHaven) — acting Security Officer
Security contact	security@fihaven.app
Version	1.0
Effective date	2026-06-08
Review cadence	At least annually and on any material change to systems or roles

This policy is a companion to the [Information Security Policy](#) and defines how access to FiHaven production assets and sensitive data is granted, restricted, reviewed, and revoked.

1. Purpose & scope

This policy governs access to all FiHaven production assets (servers, databases, hosting and provider consoles, source control) and to sensitive data (consumer financial data, Plaid access tokens, MFA secrets, credentials, and keys). It applies to all human identities (the operator and any future staff/contractors), all end-user identities, and all non-human identities (service tokens, API credentials).

2. Principles

- **Least privilege.** Identities receive the minimum access required for their function, and no more.
- **Need-to-know.** Access to sensitive data is limited to what a task requires.
- **Deny by default.** Every API request is unauthenticated and unauthorized until proven otherwise; access is explicitly granted, never implicit.
- **Zero-trust alignment.** No request is trusted based on network location. Every request to the Service is individually authenticated and authorized server-side, and every authenticated request is authorized against the acting identity's own data and role — there is no implicit trust between components.
- **Segregation.** End-user access and operator/administrative access are separate identity domains with separate controls.

3. Identities & authentication

End-user identities are managed in FiHaven's own centralized identity store (the user database):

- Passwords are hashed with **bcrypt**; credentials are never stored or logged in readable form.
- Users may enroll **phishing-resistant MFA** — WebAuthn **passkeys**, authenticator-app **TOTP**, and/or email one-time codes; MFA secrets are encrypted at rest.
- Sessions are bound server-side. Web clients use `Secure / HttpOnly / SameSite` cookies plus a per-session CSRF token; native apps store a bearer token in the platform secure store (iOS Keychain, Android EncryptedSharedPreferences).

Operator / administrative identities (server SSH, hosting console, GitHub, Plaid, Stripe, Cloudflare, DNS/mail):

- Each provider account is protected by a **strong, unique credential and MFA** wherever the provider supports it.
- Production SSH uses key-based authentication; password SSH is disabled.
- Operator workstations are full-disk-encrypted, screen-locked, and kept patched.

Non-human / service identities:

- The native apps and web client authenticate to the API with **bearer tokens** (or session cookies); machine-to-machine and provider traffic is authenticated with per-service API credentials over **TLS**.
- Provider secrets (Plaid `client_id` / `secret`, Stripe keys, SMTP credentials) are stored only in environment configuration, are environment-specific (e.g., Plaid sandbox vs. production), and are never committed to source control.

4. Role-based access control (RBAC)

Access is granted by role rather than to individuals ad hoc:

Role	Scope
User	Can read and modify only their own account and financial data. Enforced by server-side authorization on every data, account, MFA, and Plaid route.
Verified user	Data and bank/billing features additionally require a verified email.
Pro entitlement	Pro-gated features (including Plaid bank linking) require an active, server-computed entitlement.
Admin	A privileged application role for support/operations; every <code>/api/admin/*</code> route enforces the role server-side. Granted only to the operator.
Operator (infrastructure)	Host, deployment, and provider-console access; held by the Security Officer on a least-privilege basis.

Application RBAC is enforced centrally in the API authorization layer, not in the client.

5. Provisioning, changes & de-provisioning (joiner / mover / leaver)

- **Joiner.** Access is granted by the Security Officer based on role and the least-privilege principle, and only for systems the person needs.
- **Mover.** When a person's responsibilities change, their access is re-scoped to match the new role and any no-longer-needed access is removed.
- **Leaver.** When a person leaves (or a contractor engagement ends), **all** of their access — provider accounts, SSH keys, source-control membership, and any issued tokens — is revoked **promptly (target: same business day)**, and shared/affected credentials and keys are rotated. Because FiHaven is currently operated by a single person, this procedure is documented and ready to apply as the team grows.
- Issued application/session tokens can be revoked centrally; changing a user's password invalidates that user's other sessions.

6. Periodic access reviews

The Security Officer performs an access review **at least quarterly** (and on any role change), covering: provider-console accounts and their MFA status, SSH-authorized keys on production hosts, source-control collaborators, admin-role assignments, and active API/provider credentials. Unneeded access is removed and findings are recorded. Stale or unrecognized access is treated as a potential incident (see the Information Security Policy, §11).

7. Logging & monitoring of access

Authentication and access events are observable through application logs, process-manager (PM2) logs, and reverse-proxy (nginx) access/error logs; failed authentication is rate-limited. Provider consoles' own audit logs are reviewed for anomalies. Logs never contain Restricted data (tokens, secrets, passwords).

8. Enforcement, exceptions & review

Compliance with this policy is mandatory for everyone in scope. Exceptions require documented Security Officer approval, a compensating control, and a remediation date. This policy is reviewed at least annually and after material changes.

Revision history

Version	Date	Change
1.0	2026-06-08	Initial documented access control policy.